

中国研究生网络安全创新大赛

作品报告

作品名称：密证 CredProof——

面向 Python 工具的 AI 辅助安全修复与证据验收工作台

提交日期：待填

填写说明

1. 所有参赛项目必须为一个基本完整的设计。作品报告书旨在能够清晰准确地阐述（或图示）该参赛队的参赛项目（或方案）。
2. 作品报告采用A4纸撰写。除标题外，所有内容必需为宋体、小四号字、1.5倍行距。
3. 作品报告中各项目说明文字部分仅供参考，作品报告书撰写完毕后，请删除所有说明文字。（本页不删除）
4. 作品报告模板里已经列的内容仅供参考，作者可以在此基础上增加内容或对文档结构进行微调。
5. 为保证网评的公平、公正，作品报告中应避免出现作者所在学校、院系和指导教师等泄露身份的信息。一经发现，取消作品参赛资格。

目录

摘要	3
第一章 作品概述	4
第二章 作品设计与实现	5
第三章 作品测试与分析	7
第四章 贡献与创新说明	9
第五章 总结	10
参考文献	11

摘要

密证 CredProof 服务于维护自有或获授权 Python 工具的开发者与安全人员，将安全检查、AI 候选、开发者修订、程序验收和人工采纳串联为可操作流程。工具业务正常并不意味着凭据没有输出、文件没有越界、请求没有到达禁止服务。系统在隔离副本中执行必要业务测试和独立安全场景，固定访问组件提供受约束的真实文件读取与服务认证；本地模型只提出建议，开发者可查看差异并修订，技术结论由程序计算。通过检查的版本仍待人工审阅，过期或缺材料的报告不能被采纳，原仓库不会自动应用修改。本次真实综合验证中，历史 AI 候选保持 FAIL，开发者修订保留真实业务并取得原完整验收 PASS，随后以对应材料在新目录重新检查。所有历史模型失败保留；本轮不调用模型，不将人工修订算作自动修复效果。交付包含具体修订、规则、依赖、报告和可再次运行的检查。

关键词： Python 工具；AI 辅助修复；独立验收；人工采纳；材料复检

第一章 作品概述

1.1 作品价值

本作品服务于维护授权 Python/AI 工具的开发者和安全人员。使用时刻是：工具已经出现疑似泄露，需要回答“秘密通过了哪条输出路径、补丁是否真的切断、业务是否仍能工作、交付给别人时依据是否还能复查”。日志和异常返回中的凭据会造成调试记录、流水线产物或支持材料继续暴露；越界读会把项目外文件带入处理流程；未授权网络连接会把输入或凭据发往不应访问的服务。三类问题都不能只看源代码中的字面字符串。

使用者仍需提供授权范围、入口、允许目录和服务、凭据变量名、必要业务测试及禁止输出通道。系统代做的是受控触发、观察、候选补丁提交、固定验收和材料导出；规则适配与最终取舍仍由人负责。系统不访问真实账户，不自动撤销外部凭据，不对任意上传项目执行代码。

记忆点是：让 AI 提出修复，让程序决定是否接受，让开发者能够复查。

1.2 三个作品特点

1. **证据反馈进入修复过程。** 受控执行先产生脱敏观察；候选不合格时，失败事实可以进入下一次请求。h03 中第一份“脱敏”代码仍把秘密放在消息后缀，程序找到真实反例后，第二份候选改为固定安全文本并通过。

2. **修改权限和验收由程序实施。** 模型不能改需求、测试、隔离边界或直接写入原工作区。安全检查与必要业务检查同时执行，正常案例没有当前泄露证据时不因模型怀疑而自动修改。

3. **结果和对象一起交付。** 当前副本、规则、时间、报告和复检材料绑定在一起。导出后改变对象会使旧结论不再适用；复检会重新读取材料并执行必要检查，而不是只展示保存的 PASS。

1.3 应用范围与来源归属

初赛候选支持已登记的受控 Python 工具场景。固定执行器、观察器、验收器、项目接入、材料导出和界面由本项目实现；Qwen-Agent、Ollama、本地 Qwen 编码模型(历史 qwen3-coder:30b, 当前配置 qwen2.5-coder:32b-instruct-q4_K_M)、pytest、WSL/bubblewrap 及 python-dotenv/Twine 上游代码按各自许可证和来源归属。模型只提出候选；当前 component_assisted 由程序安排读取和验收，历史工具循环另列，模型不是裁判。当前记录来自合成凭据、授权模拟服务和隔离副本；它们证明受控方法可运行，不等于企业部署效果或通用漏洞覆盖。

第二章 作品设计与实现

2.1 系统组成与数据流程

开发者通过 credproof.toml 确认入口、允许修改范围、凭据变量、允许目录、服务及必要测试。ProjectWorkspace 登记项目，check_project 在既有 WSL/bubblewrap 边界中检查三类风险和真实业务。AI 入口保留 bounded_patch/component_assisted 建议能力；本轮使用已保存响应，清楚标识历史回放。ReviewWorkspace 管理 AI 候选、开发者新修订和相邻差异，调用同一 check_project，独立追加本地人工决策。流程为：检查发现问题→AI 提出候选→程序验收→开发者审阅/修订→新对象重新验收→人工决定采纳→导出与持续复检。

2.2 从疑点到固定判决

完整顺序如下：人工先确定授权和必要条件；固定程序在受控副本中执行入口与测试并产生脱敏证据；模型只接收允许代码和证据并生成候选数据，开发者可以在新副本中修订；执行器检查路径、参数、修改范围和预算；固定验收器重新运行安全、业务和边界检查；只有全部必要条件满足才 PASS，必要材料不足为 UNKNOWN，明确反例为 FAIL。

模型分析可以解释疑点；当前项目判决由 credproof_safety.project.check_project 计算，人审与项目复检分别由 human_review 和 project_bundle 管理，旧历史 bundle 接口另行保留。普通哈希只说明相对清单发生了变化，不是第三方认证、不可伪造证明或绝对安全。

2.3 三类观察与业务检查

不泄密检查匹配合成凭据是否进入 真实入口返回对象、stdout、stderr、日志或异常回执；合法向授权模拟服务提交凭据不自动算泄露。不乱读检查区分访问尝试、被拦截和有依据的成功访问。不乱连检查记录允许服务的回执、路径和禁止服务是否收到请求。业务条件检查入口返回、必要 `pytest` 的收集/执行/通过状态和必要异常行为。缺失或旧对象报告不得显示当前通过；包装器为防止递归产生的内部 `skip` 与真实必要业务测试分开统计。

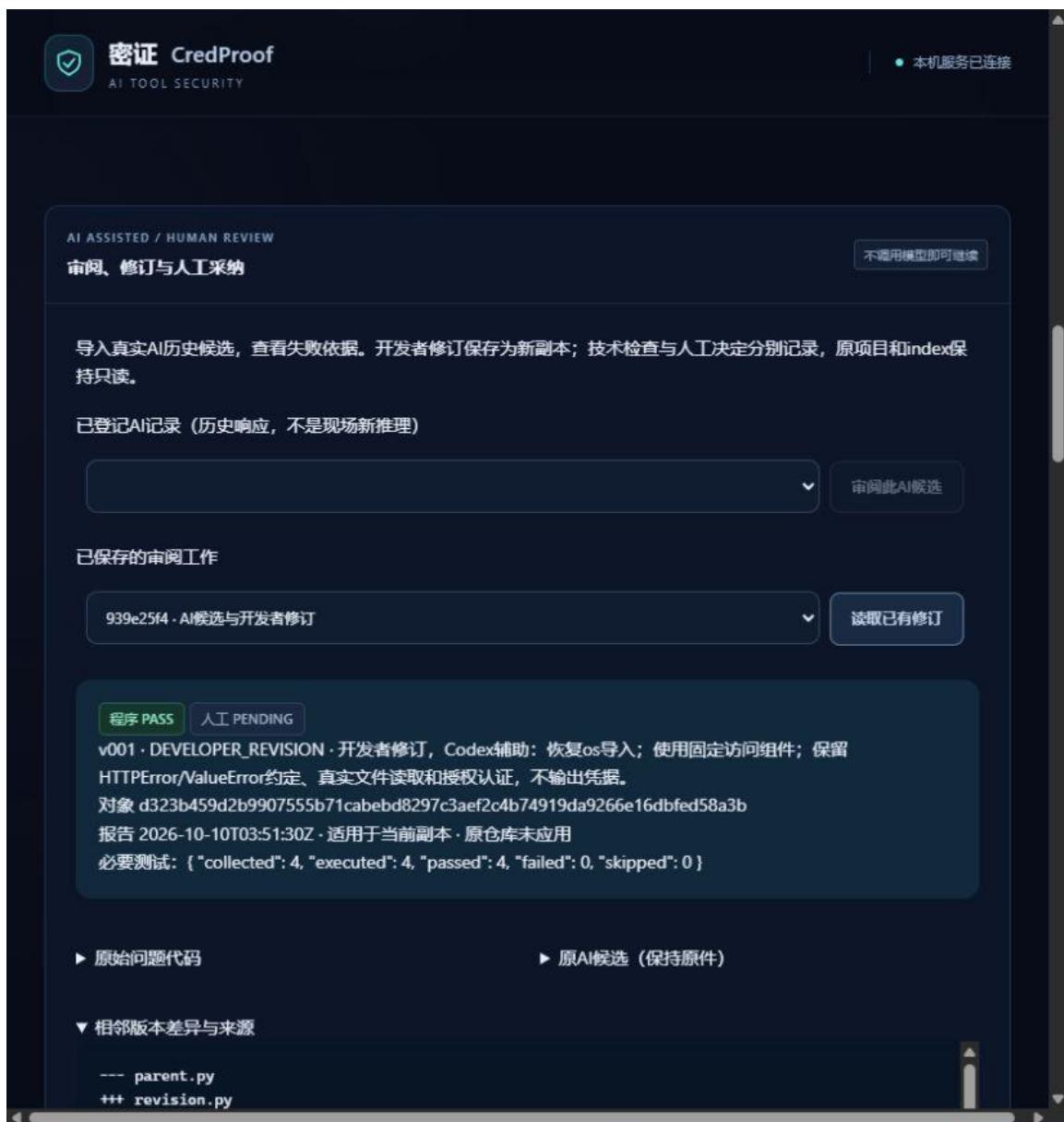


图 1 技术检查通过仍待本人采纳：已安装工作台真实记录

2.4 候选、复检与交付

浏览器只能对已登记候选提交完整授权入口源码，不能指定任意路径或修改测试、配置、组件、检查器。每次修订保存新版本、父版本、来源、摘要和理由，不覆盖原 AI 输出。程序判决 PASS/FAIL/UNKNOWN 与人工 PENDING/NEEDS_CHANGES/REJECTED/APPROVED 分开；PASS 不会自动采纳。确认采纳和已采纳导出由后端复核当前对象、原基线、配置、必要测试、依赖和报告；错误版本、过期页面或材料变化会拒绝。重新验收不恢复旧批准。FAIL/UNKNOWN 可以导出标明状态的诊断包，已验证且已采纳修复包须当前 PASS 及有效批准。采纳是本机记录，不是强身份签名；开发者自行应用副本，原项目与 index 保持只读。

第三章 作品测试与分析

3.1 测试口径

以下结果来自已保存批次，不重新拼接不同轮次。资料助手项目区和 python-dotenv 外部组件是本候选的当前无模型接入证据；历史八例和 Twine 是早期 Agent 依据，单独列出。软件测试项数不是漏洞数量，外部一个场景也不是泛化率。

3.2 资料助手项目区与导出复检

本次综合验证使用 dev35 已安装工作台及既有资料助手任务，新增运行时模型调用 0。来源完整的历史 AI 候选缺少 os 导入，并把组件 HTTPError 错误转换为 ValueError；原 FAIL 保留。开发者通过页面提交新修订，来源为“开发者修订，Codex 辅助”：恢复 os 导入，直接使用固定 read_text/get_json，保留异常约定和真实业务，不返回或记录凭据。原完整检查实际 PASS：4 项必要业务测试全部执行通过、0 跳过，正常返回及允许文件+越界跳转两个独立场景完成，真实文件读取和允许服务认证保留。正式对象保持技术 PASS、人工 PENDING。

审批功能测试使用专用副本和测试身份，覆盖 FAIL 不可采纳、PASS 可拒绝、合法采纳及导出、过期/错误版本拒绝。代码、策略、组件或必要材料变化后旧结论及批准失效，不污染正式对象。导出同一修订、组件和规则，按固定 Git 字节取件后在

5090 新目录进行无模型完整复检。既有导出消费者另外执行固定版、再引入缺陷和无关变化三个对照，结果单列，不计模型效果。原始报告及命令见当前人审评审入口。

3.3 python-dotenv 外部组件

来源为 `python-dotenv v1.2.2`，固定提交 `36004e0e34be7665ff2b11a8a4005144f76f176d`, BSD-3-Clause。原始上游代码、114 项上游测试和 3 项适配测试保留在一次性副本中；缺陷是本项目人工注入的目录越界读，不是上游漏洞、CVE 或官方修复。适配流程不调用模型，采用人工预置修复并再次引入缺陷对照。

初始注入版为 116 项通过、1 项失败，`pytest` 退出 1；不能把它写成业务测试全通过。修复版为 117 项业务测试通过，安全检查 PASS；在同一业务测试仍为 117 项通过时重新引入目录越界和凭据输出，`pytest` 退出 0，但固定安全检查为 FAIL。这个反例说明“业务绿”不能替代安全观察。无关修改保持 PASS。对应原始记录见 `experiments/reusable-tool-safety/20261004-external-dotenv-observer-v2/summary.json` 与 `20261005-pytest-case-fix-v1/external-dotenv-summary.json`。

3.4 h01 有限修复增量

h01 中凭据经环境变量进入辅助函数参数再进入日志；本项目固定启发式没有覆盖该实参到形参的关系和链式 `logger` 调用。C 候选把日志值改为脱敏文本，同时保留认证所需真实实参，十三项固定条件通过。结论只针对本项目启发式和该结构，不能推导成熟数据流工具或所有扫描器存在同样缺陷。

3.5 h03 真实反馈调整

h03 的第一份候选把 `credential=` 前缀改成 `[REDACTED]`，但真实值仍出现在消息后缀；程序的两个日志反例使它 FAIL。失败证据进入后续请求，第二份候选保留操作信息，把 `details` 改为固定安全文本，十三项条件 PASS。第一候选、第二候选和验证记录全部保留。这是一个反馈过程实例，不是对所有任务的优势证明。

3.6 h07 正常保持与完整历史批次

h07 的授权认证用途和脱敏输出没有形成当前泄露证据，系统保持原代码。它说明“模型怀疑”“程序确认”“是否允许修改”是三个不同状态，不等于模型从未误报。冻结八例完整记录中，A/B/C 问题样例合格修复为 3/4、1/4、4/4，最终对象通过为 7/8、5/8、8/8，完整任务为 7/8、4/8、6/8；未完成和失败不从统计中删除。该批次是自建合成模板留出，不是独立盲测。

3.7 Twine 历史外部依据

Twine 公开版本的配置解析错误曾令 `traceback` 携带敏感行进入 `stderr`。该单次外部任务固定源码和公开修复依据，模型提出三份候选：两份在执行前因格式/修改边界被拒，第三份通过七项受控条件。它是历史 Agent 依据，不是当前任意项目自动修复成功、上游采纳或企业部署证明；官方升级仍是实际使用者应优先考虑的处理方式。

3.8 结果解释与适用边界

当前证据支持的结论是：在已适配、隔离、合成 Python 场景中，安全观察、必要业务检查、对象绑定和复检可以共同阻止“业务测试全通过但仍泄露”的误读，并把候选修改变成可复查材料。模型的作用是提出和调整候选，固定程序负责执行、权限和判决。未测量人工节省时间、总体准确率、跨机器部署或生产影响；既有模型控制器/Ollama 白名单与私有网络边界证据保留，本轮不进行新推理或宣称扩大模型效果；更多语言与系统调用需后续适配。

第四章 贡献与创新说明

4.1 证据反馈驱动的候选生成

困难是一次性补丁可能只隐藏标签而保留秘密。项目实现 `agent_pilot/reliability.py` 的受限工具会话，将脱敏失败回执提供给后续候选；h03 的两份候选和真实日志反例给出具体依据。它相对一次性生成多做的是“在当前副本上根据新证据再提出候选”，不是新模型算法，也不声称普遍优于固定程序。

4.2 程序实施的修改授权和联合验收

本项目实现了入口范围约束、独立安全/业务检查、版本对应和人审状态控制。开发者修订也必须经过同样检查，人工决定不能覆盖技术 FAIL 或 UNKNOWN。无模型服务仍可查看和修订；缺隔离则阻断动态执行。有效人审记录绑定原基线、当前副本、配置、测试、组件及报告，决策追加保存。这是受约束工程方法与可操作工作流，不将 pytest、审批或普通哈希单独称为新算法。

4.3 对应对象的材料导出和重新验收

困难是报告可能对应旧副本，或历史轨迹缺失却仍被当作完整证据。当前项目由 credproof_safety/project_bundle.py 和 human_review.py 核对候选、配置、必要测试、依赖和引用报告；旧 agent_pilot/bundle.py 服务历史接口。导出消费者固定、缺陷、无关三个副本的 0/1/0 退出结果与三份报告可复查。普通哈希和材料完整性提示不构成第三方认证。

4.4 角色边界与归属

人工确定授权和必要条件；固定程序生成初始证据、限制工具和修改、运行隔离并作 verdict；本地模型生成候选；开发者查看差异并修订，程序重新验收，人决定采纳且不自动应用原仓库。Qwen-Agent、Ollama、pytest、WSL/bubblewrap 及上游组件不是本项目原创。AI 辅助开发范围和参赛原创声明仍由参赛者、指导教师和组委会按实际规则确认。

第五章 总结

CredProof 把“可能泄露”推进到“在当前对象上能否接受这份修复，并且别人能否复查依据”。资料助手、python-dotenv 受控接入、h01/h03/h07 和历史 Twine 共同展示问题、动作、证据和边界。作品当前应作为已适配 Python 工具的防御性验证与受控修复原型使用；后续扩展到更多语言、更多系统调用和真实部署前，仍需新的适配、隔离和独立参与者体验。

来源与 AI 参与披露

公开组件和模型按许可证与来源归属列于 docs/local-agent/reliability/source-attribution.md 及本仓库来源索引。ChatGPT/Codex 对方案、主要代码、调试、实验组织和文稿有实质辅助；本文件不代签原创或 AI 使用声明，队伍需自行向指导教师和组委会确认。

本轮范围调整与待本人确认

用户已批准 AI 辅助修复+程序独立验收+人工采纳。原“本地模型独自修复 PASS”登记 OWNER_APPROVED_SCOPE_CHANGE，自动效果仍未完成，移出当前必需范围。所有 UNKNOWN/FAIL 和原任务统计保持不变。正式修订待本人真实审阅，自动化审批只证明功能可用。队伍身份、最终文件命名、声明签署及赛事 AI 辅助开发许可仍由本人/指导教师确认；不代签、不宣称已获许可。

参考文献

1. Qwen-Agent、Ollama、pytest 及 WSL/bubblewrap 官方文档，版本和下载核验见仓库来源记录。
2. python-dotenv v1.2.2，提交 36004e0e34be7665ff2b11a8a4005144f76f176d，BSD-3-Clause；本项目注入版仅用于受控安全验证。
3. Twine 公开修复依据与本项目固定复现实验，见 docs/external-scenario/twine/。
4. experiments/local-agent-pilot/reliability/20260929t095000z-holdout8/comparison/，历史八例完整记录。